



SOC I REPORT

FOR

APPLICATION PLATFORM AS A SERVICE (APAAS)

A TYPE 2 INDEPENDENT SERVICE AUDITOR'S REPORT ON A DESCRIPTION OF A SERVICE ORGANIZATION'S
SYSTEM AND THE SUITABILITY OF THE DESIGN AND OPERATING EFFECTIVENESS OF CONTROLS

FOR THE PERIOD OCTOBER 1, 2023, TO SEPTEMBER 30, 2024

Attestation and Compliance Services



Proprietary & Confidential

Unauthorized use, reproduction, or distribution of this report, in whole or in part, is strictly prohibited.

This report is intended solely for use by the management of ServiceNow, Inc., its user entities (i.e., customers) that utilized the services covered by this report during the specified time period, and the independent financial statement auditors of those user entities (each referred to herein as a "specified user").

If the report recipient is not a specified user (herein referred to as a "non-specified user"), use of this report is the non-specified user's sole responsibility and at the non-specified user's sole and exclusive risk. Non-specified users may not rely on this report and do not acquire any rights against Schellman & Company, LLC as a result of such access. Further, Schellman & Company, LLC does not assume any duties or obligations to any non-specified user who obtains this report and/or has access to it.

Unauthorized use, reproduction, or distribution of this report, in whole or in part, is strictly prohibited.

TABLE OF CONTENTS

SECTION 1	INDEPENDENT SERVICE AUDITOR'S REPORT	1
SECTION 2	MANAGEMENT'S ASSERTION	5
SECTION 3	DESCRIPTION OF THE SYSTEM	8
SECTION 4	TESTING MATRICES	26

SECTION I

INDEPENDENT SERVICE AUDITOR'S REPORT

INDEPENDENT SERVICE AUDITOR'S REPORT

To ServiceNow, Inc.:

Scope

We have examined ServiceNow, Inc.'s ("ServiceNow" or "service organization") description of its Application Platform as a Service (APaaS) system for supporting the building, testing, deploying, and managing of web applications throughout the period October 1, 2023, to September 30, 2024 (the "description"), and the suitability of the design and operating effectiveness of controls included in the description to achieve the related control objectives stated in the description, based on criteria identified in "Management's Assertion" in Section 2 (the "assertion"). The controls and control objectives included in the description are those that management of ServiceNow believes are likely to be relevant to user entities' internal control over financial reporting, and the description does not include those aspects of the APaaS system that are not likely to be relevant to user entities' internal control over financial reporting.

The description indicates whether certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of ServiceNow's controls are suitably designed and operating effectively, along with related controls at the service organization. Our examination did not extend to such complementary user entity controls, as applicable, and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

ServiceNow uses various subservice organizations for data center hosting services. The description includes only the control objectives and related controls of ServiceNow and excludes the control objectives and related controls of the subservice organizations. The description also indicates whether certain control objectives specified by ServiceNow can be achieved only if complementary subservice organization controls assumed in the design of ServiceNow's controls are suitably designed and operating effectively, along with the related controls at ServiceNow. Our examination did not extend to controls of the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

Service Organization's Responsibilities

In Section 2, ServiceNow has provided an assertion about the fairness of the presentation of the description and suitability of the design and operating effectiveness of the controls to achieve the related control objectives stated in the description. ServiceNow is responsible for preparing the description and for the assertion, including the completeness, accuracy, and method of presentation of the description and the assertion, providing the services covered by the description, specifying the control objectives and stating them in the description, identifying the risks that threaten the achievement of the control objectives, selecting the criteria stated in the assertion, and designing, implementing, and documenting controls that are suitably designed and operating effectively to achieve the related control objectives stated in the description.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the fairness of the presentation of the description and on the suitability of the design and operating effectiveness of the controls to achieve the related control objectives stated in the description, based on our examination.

Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants (AICPA) and International Standard on Assurance Engagements (ISAE) 3402, *Assurance Reports on Controls at a Service Organization*, issued by the International Auditing and Assurance Standards Board (IAASB). Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, based on the criteria in management's assertion, the description is fairly presented and the controls were suitably designed and operating effectively to achieve the related control objectives stated in the description throughout the period October 1, 2023, to September 30, 2024. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves:

- Performing procedures to obtain evidence about the fairness of the presentation of the description and the suitability of the design and operating effectiveness of the controls to achieve the related control objectives stated in the description, based on the criteria in management's assertion.
- Assessing the risks that the description is not fairly presented and that the controls were not suitably designed or operating effectively to achieve the related control objectives stated in the description.
- Testing the operating effectiveness of those controls that management considers necessary to provide reasonable assurance that the related control objectives stated in the description were achieved.
- Evaluating the overall presentation of the description, suitability of the control objectives stated in the description, and suitability of the criteria specified by the service organization in its assertion.

Service Auditor's Independence and Quality Control

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements in the United States of America related to the examination engagement. We have complied with those requirements.

We have also applied the Statements on Quality Control Standards established by the AICPA and the International Standards on Quality Management issued by the IAASB and, accordingly, maintain a comprehensive system of quality control.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of user entities and their auditors who audit and report on user entities' financial statements and may not, therefore, include every aspect of the system that each individual user entity may consider important in its own particular environment. Because of their nature, controls at a service organization may not prevent, or detect and correct, all misstatements in supporting the building, testing, deploying, and managing of web applications. Also, the projection to the future of any evaluation of the fairness of the presentation of the description, or conclusions about the suitability of the design of the controls to achieve the related control objectives, is subject to the risk that controls at a service organization may become ineffective.

Description of Tests of Controls

The specific controls tested, and the nature, timing, and results of those tests are listed in Section 4 (the "Testing Matrices").

Opinion

In our opinion, in all material respects, based on the criteria described in ServiceNow's assertion in Section 2:

- a. the description fairly presents the APaaS system that was designed and implemented throughout the period October 1, 2023, to September 30, 2024;
- b. the controls related to the control objectives stated in the description were suitably designed to provide reasonable assurance that the control objectives would be achieved if the controls operated effectively throughout the period October 1, 2023, to September 30, 2024, and as applicable, subservice organizations and user entities applied the complementary controls assumed in the design of ServiceNow's controls throughout the period October 1, 2023, to September 30, 2024; and
- c. the controls operated effectively to provide reasonable assurance that the control objectives stated in the description were achieved throughout the period October 1, 2023, to September 30, 2024, if, as applicable, complementary subservice organization and user entity controls assumed in the design of ServiceNow's controls operated effectively throughout the period October 1, 2023, to September 30, 2024.

Restricted Use

This report, including the description of the tests of controls and results thereof in the Testing Matrices, is intended solely for the information and use of management of ServiceNow, user entities of ServiceNow's APaaS system

during some or all of the period October 1, 2023, to September 30, 2024, and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by user entities themselves, when assessing the risks of material misstatement of user entities' financial statements. This report is not intended to be, and should not be, used by anyone other than the specified parties.

SCHULMAN & COMPANY, LLC

Tampa, Florida
October 21, 2024

SECTION 2

MANAGEMENT'S ASSERTION

MANAGEMENT'S ASSERTION

We have prepared the description of ServiceNow, Inc.'s ("ServiceNow") APaaS system for supporting the building, testing, deploying, and managing of web applications throughout the period October 1, 2023, to September 30, 2024 (the "description"), for user entities of the system during some or all of the period October 1, 2023, to September 30, 2024, and their auditors who audit and report on such user entities' financial statements or internal control over financial reporting and have a sufficient understanding to consider it, along with other information, including information about controls implemented by subservice organizations and user entities of the system themselves, when assessing the risks of material misstatement of user entities' financial statements.

ServiceNow uses various subservice organizations for data center hosting services. The description includes only the control objectives and related controls of ServiceNow and excludes the control objectives and related controls of the subservice organizations. The description also indicates whether certain control objectives specified in the description can be achieved only if complementary subservice organization controls assumed in the design of our controls are suitably designed and operating effectively, along with the related controls. The description does not extend to controls of the subservice organizations.

The description indicates whether certain control objectives specified in the description can be achieved only if complementary user entity controls assumed in the design of ServiceNow's controls are suitably designed and operating effectively, along with related controls at ServiceNow. The description does not extend to controls of the user entities.

We confirm, to the best of our knowledge and belief, that:

- a. the description fairly presents the APaaS system made available to user entities of the system during some or all of the period October 1, 2023, to September 30, 2024, for supporting the building, testing, deploying, and managing of web applications as it relates to controls that are likely to be relevant to user entities' internal control over financial reporting. The criteria we used in making this assertion were that the description:
 - i. presents how the system made available to user entities of the system was designed and implemented to process relevant user entity transactions, including, as applicable:
 - (1) the types of services provided including, as appropriate, the classes of transactions processed;
 - (2) the procedures, within both automated and manual systems, by which those services are provided, including, as appropriate, procedures by which transactions are initiated, authorized, recorded, processed, corrected as necessary, and transferred to reports and other information prepared for user entities of the system;
 - (3) the information used in the performance of the procedures including, if applicable, related accounting records, whether electronic or manual, and supporting information involved in initiating, authorizing, recording, processing, and reporting transactions; this includes the correction of incorrect information and how information is transferred to the reports and other information prepared for user entities;
 - (4) how the system captures and addresses significant events and conditions, other than transactions;
 - (5) the process used to prepare reports or other information provided for entities;
 - (6) services performed by a subservice organization, if any, including whether the carve-out method or the inclusive method has been used in relation to them;
 - (7) the specified control objectives and controls designed to achieve those objectives, including as applicable, complementary user entity controls and complementary subservice organization controls assumed in the design of the ServiceNow's controls; and

- (8) other aspects of our control environment, risk assessment process, information and communication systems (including the related business processes), control activities, and monitoring activities that are relevant to the services provided;
- ii. includes relevant details of changes to the APaaS system during the period covered by the description; and
- iii. does not omit or distort information relevant to the scope of the APaaS system, while acknowledging that the description is prepared to meet the common needs of a broad range of user entities of the system and their user auditors, and may not, therefore, include every aspect of the APaaS system that each individual user entity of the system and its auditor may consider important in its own particular environment; and
- b. the controls related to the control objectives stated in the description were suitably designed and operating effectively throughout the period October 1, 2023, to September 30, 2024, to achieve those control objectives if, as applicable, subservice organizations and user entities applied complementary controls assumed in the design of ServiceNow's controls throughout the period October 1, 2023, to September 30, 2024. The criteria we used in making this assertion were that:
 - i. the risks that threaten the achievement of the control objectives stated in the description have been identified by management of ServiceNow;
 - ii. the controls identified in the description would, if operating effectively, provide reasonable assurance that those risks would not prevent the control objectives stated in the description from being achieved; and
 - iii. the controls were consistently applied as designed, including whether manual controls were applied by individuals who have the appropriate competence and authority.

SECTION 3

DESCRIPTION OF THE SYSTEM

OVERVIEW OF OPERATIONS

Company Background

ServiceNow is a provider of enterprise cloud computing services that define, structure, manage, and automate digital workflows for global enterprises. The company delivers digital workflows that help their customers create experiences and unlock productivity. The ServiceNow Now Platform enables enterprise-wide experiences and productivity by simplifying and streamlining processes across systems, functions, and departments. The ServiceNow product portfolio focuses on delivering information technology (IT), employee and customer workflows, and enabling customers to build workflow applications for their business. In addition to the ServiceNow IT service management applications, ServiceNow provides digital workflow products for customer service, global talent, security operations, integrated risk management (including compliance, risk, and audit), and other enterprise departments where a patchwork of semi-automated and manual processes had been used in the past.

ServiceNow offers its service as cloud-based solutions that customers can deploy in a modular fashion, allowing them to solve immediate business needs and access, configure, and build new applications as their requirements evolve. ServiceNow's service, which is accessed through a web-based interface, can be easily configured to adapt to customer workflows and processes. Upgrades to ServiceNow's service are designed to be efficient and compatible with configuration changes and applied with minimal disruption to ongoing operations.

ServiceNow employs approximately 24,000 employees around the world that serve to support over 8,100 customers. The global company headquarters is located in Santa Clara, California, while the Amsterdam office serves as the headquarters for Europe, the Middle East, and Africa (EMEA), and the Singapore office serves as the headquarters for Asia Pacific (AP). Major support and operations centers are located in San Diego, California; Kirkland, Washington; Chicago, Illinois; Orlando, Florida; Amsterdam, the Netherlands; London, United Kingdom; Sydney, Australia; Singapore; Hyderabad, India; and Dublin, Ireland.

Description of Services Provided

ServiceNow develops and maintains a software platform that provides cloud-based solutions that define, structure, manage and automate services across the global enterprise. The ServiceNow Application Platform as a Service (APaaS), including the Now Platform and Stream Connect for Apache Kafka (the "System"), is built to serve many types of business users including the executive level, functional IT staff, application developers, IT operations, and finance. ServiceNow provides cloud-based solutions across a common platform with supporting applications; applications can be customized by customers while still providing a consistent and intuitive user experience through the entire service lifecycle.

Now Platform

ServiceNow cloud services are built on the company's proprietary platform, the Now Platform®, which features one code base and one data model. It enables customers to create, by themselves or with ServiceNow partners, their own service-oriented business applications across the enterprise. ServiceNow primarily delivers the Now Platform via the Internet as a service, through a consumer product-like interface, which means it can be configured and rapidly deployed.

Stream Connect for Apache Kafka

Stream Connect for Apache Kafka allows customers to connect their Kafka environment to their ServiceNow instance enabling data to be streamed between the instance and external systems. Producers send data from the instance to the Kafka environment. Consumers retrieve data from the Kafka environment into the instance. Between the instance and the customer's Kafka environment, data flows through a messaging queue hosted on dedicated infrastructure.

The APaaS environment is an information technology general control (ITGC) system, and user entities are responsible for the procedures, by which transactions are initiated, authorized, recorded, processed, corrected as necessary, and transferred to reports and other information presented to them; additionally, user entities are responsible for the procedures and controls governing the related accounting records, supporting information, and

specific accounts that are used to initiate, authorize, record, process, and report transactions processed within the APaaS system; this includes the correction of incorrect information and how information is transferred to the reports and other information prepared for those user entities.

Customer requests for services are initiated and authorized by user entities by directly contacting the customer support department. Customer requests are recorded and track entities within an internal tracking system through resolution. The ticketing system is utilized to document, escalate, and resolve problems affecting the contracted services. Customer requests are managed according to established service level agreements.

System Boundaries

A system is designed, implemented, and operated to achieve specific business objectives in accordance with management-specified requirements. The purpose of the system description is to delineate the boundaries of the system, which includes the services outlined above and the system components described below.

Infrastructure and Software

The ServiceNow APaaS production infrastructure is located at the following data center locations: Amsterdam, Arizona, Bangalore, Brampton, Calgary, California, Dublin, Dusseldorf, Frankfurt, Geneva, Illinois, London, Melbourne, Mumbai, Osaka, Rio de Janeiro, Sao Paulo, Seoul, Singapore, Sydney, Texas, Tokyo, Virginia, Wales, and Zurich; and are grouped in pairs to provide a geographically diverse active / active architecture for each production customer instance.

The in-scope infrastructure consists of multiple applications, operating system platforms and databases, as shown in the table below:

Primary Infrastructure			
Production System	Business Function Description	Operating System Platform	Physical Location
Now Platform	Application platform supporting the APaaS system.	Linux / Apache Web Server	Production data centers
Stream Connect for Apache Kafka	Application platform supporting the Stream Connect for Apache Kafka system.		
Database	Primary database engine supporting the APaaS system.	MariaDB	
		Postgres	
Active Directory (AD)	Authenticates and authorizes users and computers in ServiceNow's corporate Windows domain network.	Windows	
OpenLDAP	Access to the application and database operating systems, and some internal applications is governed by the OpenLDAP centralized Lightweight Directory Access Protocol (LDAP) system.	Linux	
Virtual Private Network (VPN)	Provides the means of authentication for administrators to access the production network.	Palo Alto	
Firewalls	Redundant firewall systems utilized filter incoming and outgoing network traffic.		

In addition, ServiceNow utilizes the following applications and utilities to support the System:

- Splunk – security information and event management (SIEM) tool utilized to provide centralized log management and file integrity monitoring.
- Puppet – enforces configuration policy and ensures consistency across servers.
- RSA – provides multi-factor authentication for access to the production network.

- SailPoint – provides identity and access management.
- Datacenter – instance of ServiceNow that is used to provide cloud infrastructure monitoring, automation, and other features, to support the cloud environment.
- Workday – cloud-based human resources information system (HRIS) utilized for managing employee data and initiating the process of user access provisioning and deprovisioning.
- Xymon / Monitoring as a Service (MaaS) – internally developed monitoring service stack that collects data on each infrastructure server.
- OSSEC – performs file integrity monitoring on servers.
- Suricata – performs intrusion detection of the production network.
- Now Support Portal – instance of ServiceNow that is used for infrastructure change management ticketing, customer support ticketing.

People

Personnel supporting the ServiceNow APaaS includes, but is not limited to, the following:

- Chief Executive Officer (CEO) – owns executive management and is responsible for overseeing company-wide activities, establishing, and accomplishing goals, and overseeing objectives.
- Chief Financial Officer (CFO) – owns finance, legal, and audit, risk and control assurance and is responsible for the day-to-day operations and support of the company.
- Chief People Officer (CPO) – owns Global People and is responsible for human resource activities.
- Chief Information Officer (CIO) – owns IT operations and is responsible for the management of the corporate infrastructure and network.
- Chief Information Security Officer (CISO) – owns security architecture, engineering, application, and operations (security, vulnerability management, etc.) and is responsible for the design and implementation of the security infrastructure, and processes relating to the ServiceNow APaaS.
- Chief Product Officer (CPO) – owns the following:
 - Cloud development – responsible for developing cloud automation and technology to maintain, automate, and monitor the infrastructure.
 - Development – responsible for the development, testing, and internal communication regarding changes to the System.
 - Program managers and release executive team – responsible for managing the release process and approving releases.
 - Site reliability engineering (SRE) – responsible for monitoring and supporting the availability of the ServiceNow APaaS.
 - System engineering and cloud infrastructure – responsible for the management of infrastructure servers, network devices, and data center operations as well as developing new technology to improve the availability and quality of product service provided to customers.
 - Customer support – responsible for resolving customer cases and serves as the initial point of contact for customer related cases.

Data Management

Data processing is the core purpose of the ServiceNow cloud-based enterprise solutions system and services. Customers store and process data on ServiceNow's cloud-based enterprise solutions system and services in support of business and IT functions within their organizations. Customers can use Stream Connect for Apache Kafka to connect their Kafka environment to their ServiceNow instance enabling data to be streamed between the instance and external systems. ServiceNow does not analyze or process the data on behalf of their customers.

The following table describes the information used and supported by the system.

Data Used and Supported by the System	
Data Description	Data Reporting
Application data supported by the APaaS system consists of customer inputs relating to the automation of customer IT and business processes including the following: • Asset management • Change management • Cloud provisioning • Configuration management • Discovery and application dependency mapping • Incident and problem management • Governance risk and compliance • Orchestration • Performance analytics • Project and portfolio management • Service automation platform • Service catalog and request fulfillment	The system can be utilized by the customer to generate various exports and customizable reports, including the following: • IT performance reporting and analytics • Business services mapping • Root cause and risk analysis • Process management workflows • Service level and spot trending • Service and inventory cataloging • Point-and-click graphical dashboards

Subservice Organizations

ServiceNow utilizes the data center hosting services provided by CyrusOne, Digital Realty Trust, Equinix, eStruxture, Next Generation Data, and NTT. ServiceNow's APaaS system was designed with the assumption that no subservice organization controls were required in the design of ServiceNow's controls; therefore, no control objectives related to ServiceNow's APaaS system are dependent upon complementary subservice organization controls that are suitably designed and operating effectively, along with the related controls at ServiceNow.

Significant Changes During the Period

There were no significant changes that are likely to affect report users' understanding of how the in-scope system is used to provide the services covered by this examination during the period.

CONTROL ENVIRONMENT

The control environment at ServiceNow is the foundation for the other areas of internal control. It sets the tone of the organization and influences the control consciousness of its personnel. The components of the control environment factors include the integrity and ethical values, management's commitment to competence; its organizational structure; the assignment of authority and responsibility; and the oversight and direction provided by the board of directors and operations management.

Integrity and Ethical Values

The effectiveness of controls cannot rise above the integrity and ethical values of the people who create, administer, and monitor them. Integrity and ethical values are essential elements of ServiceNow's control environment, affecting the design, administration, and monitoring of other components. Integrity and ethical behavior are the product of ServiceNow's ethical and behavioral standards, how they are communicated, and how they are reinforced in practices. They include management's actions to remove or reduce incentives and temptations that

might prompt personnel to engage in dishonest, illegal, or unethical acts. They also include the communication of entity values and behavioral standards to personnel through policy statements and codes of conduct as well as by example. Specific control activities that ServiceNow has implemented in this area are described below:

- A documented code of conduct and an acceptable use policy are in place to facilitate reducing incentives and temptations for personnel to engage in dishonest, illegal, or unethical acts. Each employee acknowledges that they have read and received those documents.
- Employees undergo code of conduct, ethics, and insider trading training annually.
- Employees and contractors are required to consent to a background check and drug test, as permissible per local law, as a component of the hiring process, and are subject to rescreening at the discretion of management.

Board of Directors Oversight

ServiceNow's control consciousness is influenced significantly by its board of directors. Attributes that define the entity's "tone at the top" established by the board of directors include the board of directors' independence from management, the experience and stature of its members, the extent of its involvement and scrutiny of activities, the appropriateness of its actions, the degree to which difficult questions are raised and pursued with management, and its interaction with internal and external auditors. The board of directors meets once a quarter to evaluate the company's operations. The board of directors is comprised of eleven members, ten of whom are independent from management. Matters are discussed in open sessions and formal meeting minutes captured.

Organizational Structure and Assignment of Authority and Responsibility

ServiceNow's organizational structure provides the framework within which its activities for achieving entity-wide objectives are planned, executed, controlled, and monitored. Establishing a relevant organizational structure includes considering key areas of authority and responsibility and appropriate lines of reporting. The appropriateness of ServiceNow's organizational structure includes how authority and responsibility for operating activities are assigned and how reporting relationships and authorization hierarchies are established. It also includes policies relating to appropriate business practices, knowledge and experience of key personnel, and resources provided for carrying out duties. In addition, it includes policies and communications directed at ensuring personnel understand the entity's objectives, know how their individual actions interrelate and contribute to those objectives, and recognize how and for what they will be held accountable. Organizational charts are in place to communicate key areas of authority, responsibility, and lines of reporting to personnel. These charts are available to employees at any time via an internal system and updated as needed.

Commitment to Competence

Competence is the knowledge and skills necessary to accomplish tasks that define the individual's job. Commitment to competence includes management's consideration of the competence levels for particular jobs and how those levels translate into requisite skills and knowledge. Specific control activities that ServiceNow has implemented in this area are described below:

- Documented position descriptions are in place to specify the qualification, education, and experience required for the competence levels of particular jobs.
- Management formally evaluates employee performance on an annual basis and informally throughout the calendar year.

Accountability

Management's philosophy and operating style encompass a broad range of characteristics. Such characteristics may include the following: management's approach to taking and monitoring business risks; and management's attitudes toward information processing, accounting functions, and personnel.

Specific control activities that ServiceNow has implemented in this area are described below:

- Management periodically briefed on regulatory and industry changes affecting services provided.
- Management meetings are held on a weekly basis to discuss operational issues.
- All hands meetings are held on a quarterly basis to communicate company-wide objectives.
- Departmental meetings are held on a quarterly basis to discuss department-level objectives.
- Periodic security and risk oversight meetings are held to discuss the security and risk items that are relevant to the organization.
- Annual security management meetings occur to oversee the security program, communicate security across the organization, and review risks and security issues.

Human resources policies and practices relate to hiring, orientation, training, evaluating, counseling, promoting, compensating, and remediating actions. Standards for hiring the most qualified individuals – with emphasis on educational background, prior work experience, past accomplishments, and evidence of integrity and ethical behavior demonstrate an entity's commitment to competent and trustworthy people. Training policies that communicate prospective roles and responsibilities and include practices such as training schools and seminars illustrate expected levels of performance and behavior. Promotions driven by periodic performance appraisals demonstrate the entity's commitment to the advancement of qualified personnel to higher levels of responsibility. Specific control activities that ServiceNow has implemented in this area are described below:

- Documented policies and procedures are in place addressing human resources operations and practices.
- The new hire process is documented for newly hired employees to help ensure that the required steps in the new hire process are completed.
- The termination process is documented for terminated employees to help ensure that the required steps in the termination process are completed.

RISK ASSESSMENT

Management is responsible for identifying the risks that threaten achievement of the control objectives stated in the management's description of the service organization's systems. Management has implemented a process for risk assessment. This process includes risk identification, risk analysis and risk evaluation.

Risk Identification

Regardless of whether an objective is stated or implied, ServiceNow's risk assessment process considers risks that may occur. It is important that risk identification be comprehensive in finding, recognizing, and recording risks. ServiceNow has considered significant interactions between itself and relevant external parties and risks that could affect the organization's ability to provide reliable services to its user entities.

Risk Factors

Management considers risks that can arise from both external and internal factors including the following:

External Factors

- Technological developments
- Changing customer needs or expectations
- Competition that could alter marketing or service activities
- New legislation and regulation that could force changes in policies and strategies

- Natural catastrophes that could lead to changes in operations or information systems
- Economic changes that could have an impact on management decisions

Internal Factors

- Significant changes in policies, processes, or personnel
- Types of fraud, fraud incentives, and pressures for employees, fraud opportunities, and employee attitudes and rationalizations for fraud
- A disruption in information systems processing
- The quality of personnel hired, and methods of training utilized
- Changes in management responsibilities

The ServiceNow risk assessment process focuses on supporting management decisions and responding to potential threats by assessing risks and identifying important decision factors. ServiceNow senior management oversees risk management ownership, accountability, and is involved in the risk identification process. Management identifies elements of business risk including threats, vulnerabilities, safeguards, and the likelihood of a threat, to determine the actions to be taken.

Risk Analysis

Risk analysis is about developing an understanding of the risk. It provides an input to risk assessment and to decisions about whether risks need to be treated and about the proper treatment strategies and methods.

ServiceNow's methodology for analyzing risks varies, largely because many risks are difficult to quantify. Nonetheless, the process includes:

- Estimating the impact of a risk
- Assessing the impact and likelihood (or frequency) of the risk occurring
- Determining the inherent risk (absence of controls)
- Considering the adequacy and effectiveness of existing controls that will help mitigate the risk, including:
 - Identifying any weaknesses with existing controls
 - Identifying any additional controls needed to further mitigate the impact and/or likelihood of the risk
- Determining the residual risk considering existing controls
- Considering how the risk should be managed, including an assessment of what actions need to be taken

Risk analysis is an essential process to the entity's success. It includes identification of key business processes where potential exposures of some consequence exist. How the risk should be managed involves judgment based on assumptions about the risk, and reasonable analysis of costs associated with reducing the level of risk. Necessary actions are taken to reduce the impact or likelihood of the risk occurring.

Risk Evaluation

Risk evaluation involves comparing estimated levels of risk with risk criteria in order to determine the significance of the level and type of risk. Risk evaluation uses the understanding of risk obtained during risk analysis to make decisions about future actions. Ethical, legal, financial, and other considerations, including perceptions of risk, are also inputs to the decision. Decisions for risk handling may include:

- Whether a risk needs treatment and priorities for risk treatment
- Whether an activity should be undertaken to mitigate the risk
- Which path and/or paths should be followed to mitigate the risk

Integration with Control Objectives

Along with assessing risks, management has identified and put into effect actions needed to address those risks. In order to address risks, control objectives have been defined for each significant risk area. Continuous control monitoring activities are then implemented to serve as mechanisms for managing the achievement of those objectives and help ensure that control implementations are adequately designed and operating effectively.

CONTROL OBJECTIVES AND RELATED CONTROL ACTIVITIES

Selection and Development of Control Activities

Control activities are a part of the process by which ServiceNow strives to achieve its business objectives. ServiceNow has applied a risk management approach to the organization in order to select and develop control activities. After relevant risks have been identified and evaluated, control activities are established to meet the overall objectives of the organization.

The establishment of control activities is inclusive of general control activities over technology. The management personnel of ServiceNow evaluate the relationships between business processes and the use technology to perform those processes to determine the dependencies on technology. The security management processes for the technology, along with other factors, are analyzed to define and establish the necessary control activities to achieve control objectives that include technology.

The establishment of the control activities is enforced by defined policies and procedures that specifically state management's directives for ServiceNow personnel. The policies serve as the rules that personnel must follow when implementing certain control activities. The procedures are the series of steps the personnel should follow when performing business or technology processes and the control activities that are components of those processes. After the policies, procedures and control activities are all established, each are implemented, monitored, reviewed, and improved when necessary.

ServiceNow's control objectives and related control activities are included below and also in Section 4 (the "Testing Matrices") of this report.

The description of the service auditor's tests of operating effectiveness and the results of those tests are also presented in the Testing Matrices, adjacent to the service organization's description of control activities. The description of the tests of operating effectiveness and the results of those tests are the responsibility of the service auditor and should be considered information provided by the service auditor.

Data Backup

Control Objective: Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up regularly and is available for restoration in the event of processing errors or unexpected processing interruptions.

Documented backup procedures are in place to guide personnel in the data backup and recovery process that include, but are not limited to, the following: data replication, record retention, and secure data destruction. Each Now Platform instance is locally backed up in the data center in which the instance database exists. This process follows a frequency of one weekly full backup followed by six differential daily backups. These backups are stored locally to disk within the respective data center; these backups do not leave the data center cages. The automated backup system is configured to retain at least six daily differential backups of production databases since the last full backup and at least two weekly full backups of production databases.

ServiceNow also maintains data center pairs throughout the world for availability and redundancy purposes. Customer data is stored in the data center pair selected by the customer during the ordering process. Management

has configured hosted production customer data files within databases to be fully replicated on a continuous basis. Once files in a customer's database have changed, they are replicated to a data center located in a geographically different location on a near real-time basis. Programmed scripts within the customer's database instance execute the replication command.

If the replication fails or falls behind the primary database by a pre-defined amount of time, an alert notification is sent to the monitoring console. The monitoring console will display an alert on-screen within the operations center, which is monitored 24 hours per day. SRE personnel will work to resolve the alert and will log the event in the ticketing system.

Access to recall the replicated data is restricted to user accounts accessible by authorized cloud operations personnel.

ServiceNow has established the Information System Contingency Plan (ISCP) to recover the ServiceNow APaaS. The ISCP is designed to document a well-structured and easily understood plan which will help ServiceNow personnel recover operations as quickly and effectively as possible from a disaster or emergency which interrupts information systems and business operations. In addition, the ISCP is tested against multiple scenarios including, but not limited to, data failover and backup restoration on an annual basis to ensure the plan is up to date.

Systems Monitoring

Control Objective: Controls provide reasonable assurance that production problems, systems processing, and availability issues are monitored, identified, recorded, analyzed, and resolved completely and in a timely manner.

Availability monitoring is performed, and established warnings and alerts are displayed via a dashboard to security staff who monitor the dashboard 24x7. Dependent on the warning / alert content, Case or Change tickets can be opened to request action to resolve the warning / alert.

Case management procedures are documented to restore normal service operation to customers as quickly as possible and to minimize the impact on their business operations. These procedures include guidelines for prioritization based on impact to operations and to customers. ServiceNow utilizes the Now Support Portal for communicating and tracking any identified cases, and updates are provided within the ticket for affected customers as available. When an issue is detected (from internal monitoring), or reported by a customer, ServiceNow personnel will examine the issue, create a ticket within the Now Support Portal, and attempt to troubleshoot the issue. If the individual assigned to the ticket cannot troubleshoot the issue, the ticket is escalated to the necessary individuals to resolve the issue. Status updates are logged within the ticket where customers can view status. A root cause investigation is performed on each P1 classified case.

Cases found to have security implications are routed to the security team for investigation, triage, and remediation. As part of their triage procedures, the security team determines the data classification of any impacted data assets, and if impacted data is classified as "Customer Restricted", security works with Customer Support to report to affected customers. A security incident response team (SIRT) is assembled to analyze, determine the impact to customers, and where necessary, develop a remediation plan and perform a root cause analysis. This process follows the defined Security Incident Response process.

Information Security

Control Objective: Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.

ServiceNow has implemented an information security program consisting of a set of policies and procedures that define how system information is entered, managed, and protected. These policies address acceptable use, access controls, password management and auditing / logging.

These policies are reviewed on at least an annual basis and readily available for company personnel to review and understand their responsibility for adhering to the associated organizational standards and security requirements.

In addition, personnel are required to complete security awareness training upon hire and each calendar year thereafter to help ensure awareness of security policies and procedures. The ServiceNow security behavior team tracks completion of the annual security awareness training to help ensure employees have completed the training.

ServiceNow has established an on-boarding process for hiring new employees to minimize the risk of malicious behavior and to ensure that new employees understand the policies for maintaining a secure workplace. An acceptable use policy has been created to minimize inappropriate usage of computing facilities. Users are required to sign an electronic acknowledgment signifying that they have been given access to the code of conduct and ethics, acceptable use and information security policies and agree to adhere to the established guidelines. In addition, ServiceNow requires performance of background verification checks and drug testing for employees prior to the hiring of new employees to the extent permitted by law.

Access Administration

Access to customer systems and information is protected by authentication and authorization mechanisms. User authentication is required to gain access to ServiceNow's production systems including the network, and to application and database servers. Further, ServiceNow employees who manage and support customer instances may be required to gain access for this sole purpose. Staff members in a job role that could require access to customer instances belong to a security role (entitlement) that are reviewed on a quarterly basis. Administrative access privileges to the network security authentication application are restricted to security engineers and IT operations personnel. Administrative access privileges to the application and database server operating systems are restricted to members of the cloud operations group including security, network, database, system, and development (as needed for troubleshooting, production debugging, and testing) personnel.

The IT operations, cloud operations and security teams are responsible for assigning and maintaining access rights to the production network, and application and database servers. In order to access the production application and database servers, users first authenticate to the ServiceNow production network, which is governed by the RSA SecurID network security authentication application. Access to the application and database operating systems is governed by a centralized LDAP system. Cloud personnel assign access privileges based on the minimal level of access required to complete job functions. System administrators document logical access provisioning requests within access request tickets. Access administration to client application instances is not managed by ServiceNow and is the responsibility of the client.

Authentication

Production network users are required to authenticate to the production network using a VPN client with multi-factor authentication. The network security application is configured to enforce user account and password controls including minimum personal identification number (PIN) aging (periodic expiration) and minimum PIN length.

The following AD password requirements for endpoints operating system are configured:

- Minimum password length
- Minimum password history
- Password expiration intervals
- Invalid password account lockout threshold
- Password complexity

The application and database server operating system are configured to enforce the following user account and password controls and is centrally managed using LDAP:

- Minimum password length
- Minimum password history
- Password expiration intervals
- Invalid password account lockout threshold
- Password complexity

Access Requests and Access Revocation

SailPoint is used to automate the provisioning and deprovisioning of access to key systems within the production environment to include LDAP (which is the authentication mechanism used in infrastructure authentication), Now Support, Datacenter, and AD. Birth right access is auto provisioned by SailPoint upon hire, and managers request additional role / group access within the onboarding ticket.

Ongoing access requests are documented in a request ticket and elevated privilege requests are required to be approved by appropriate personnel (management or their designate).

To help ensure access privileges are appropriate, the Identity and Access Management team completes an audit of user accounts on a quarterly basis to verify access to high-risk systems remains commensurate with job responsibilities. If any individual is identified to have inappropriate access, it is immediately remediated.

Upon notification of an employee termination, an offboarding ticket is opened to initiate the process. Termination date and last day worked is entered into the ticketing system among other details. On the last day worked, the HRIS is automatically updated to show the employee is no longer active. An automated job from SailPoint syncs with the HRIS, and any users newly marked as inactive are processed through the leaver job, which deactivates high-risk system access.

In a separate process, ServiceNow employees who manage, and support customer instances of the Now Platform may be required to gain access to a customer instance of the Now Platform to address customer-specific support requests for a change, address a case or perform a customer-specified task in response to a change or case ticket. Access is provisioned by automation and is only enabled for the specified instance which is listed in the ticket. If the staff member belongs to this security role, they gain access to a customer instance via a hardened jump box virtual machine. When the ticket is closed, the privileges are automatically removed. Customers can disable this capability by deploying the ServiceNow Controlled Access (SNCA) plugin, which blocks ServiceNow's ability to access their instance. Any access to or actions performed by a ServiceNow support team member on behalf of the client is automatically recorded in the platform transaction logs of the customer instance for customer monitoring.

Logging and Monitoring

The production network and application and database servers are configured to log activity that includes logging attempts and privileged command use. Logging alerts are monitored in a centralized SIEM tool. Security personnel reviews automated logging alert notifications for anomalies on an on-going basis. The Identity and Access Management (IAM) team performs quarterly user access reviews of the production network security authentication application, application and database servers, and other critical systems to ensure that user access privileges are appropriate.

Column Level Encryption

For users selecting column level encryption, encrypted fields are stored in the database as unreadable cipher text using Advanced Encryption Standard (AES) 128-bit or AES 256-bit encryption, depending on customer selection. Access to encrypted fields at the application-level is role-based.

Data Communications

Control Objective: Controls provide reasonable assurance that network infrastructure is configured as authorized to protect data relevant to user entities' internal control over financial reporting from unauthorized changes, and to support user entities' internal control over financial reporting.

Firewall System

A firewall system is installed and utilized to protect ServiceNow production systems. The firewall resides on the network and analyzes data and packets routed to the ServiceNow environment. Any external Internet traffic is required to pass through the firewall to communicate with the production servers. Cloud operations personnel are responsible for administering the firewall and have implemented the following configurations in order to reduce the likelihood of unauthorized or unintentional interception of data in transit. Any type of connection that is not explicitly authorized by the firewall will be denied.

Firewall administrators are required to authenticate via a VPN client to the production network and then connect utilizing secure shell (SSH) encryption to gain access to the firewall systems. The firewall system requires administrators to authenticate via a user account, PIN, and token in order to access the firewall ruleset. Administrative access to the firewall system is restricted to authorized cloud operations personnel. Additionally, changes to the firewall cannot be executed without prior authorization by the SRE team.

Cloud and security personnel utilize a centralized monitoring system to monitor and log activity within the firewall system that includes, but is not limited to the following:

- Failed connections
- Permitted connections to specific destinations
- Denied connections to specific destinations

Security personnel review server and firewall logs via the SIEM tool dashboards on a daily basis, and the security team is on-call on a 24-hour basis.

Intrusion Detection (IDS) and File Integrity Monitoring (FIM) Systems

Management utilizes an IDS to monitor the production servers and network for potential or actual security breaches. The IDS is configured to analyze network events and to notify security personnel via alerting dashboards in real-time within the SIEM tool when suspected or actual network security breaches are detected. In addition to the IDS, the utility is also enabled with FIM functionality to monitor the APaaS production servers for any changes that are made to critical operating system directories. Dedicated security personnel monitor the alerting dashboards on a continuous basis. Application and database servers are centrally managed using a server configuration tool.

Application Change Control

Control Objective: Controls provide reasonable assurance that changes to programs and related data management systems are authorized, tested, documented, approved, and implemented to support user entities' internal control over financial reporting.

Now Platform software development changes are initiated as a result of the collaborative effort between the development organization and customer input. ServiceNow utilizes the Scrum Agile software development methodology, which provides a framework for software development and planning activities. Documented software development and release management procedures are in place to guide personnel in application change management practices that include, but are not limited to, the following: System Development Life Cycle (SDLC) procedure, Verification procedure, and Maintenance Release management procedure. Documented coding standards and guidelines are in place to guide the application development process and establish basic secure coding practices. Development activities are performed in distinct environments that are logically separate from production in order to ensure that changes made within the test environment do not affect changes in the production environment. Development personnel utilize third-party version control software to manage versions of source code. The tool allows development personnel to check out different versions of the code and to store it locally on their computer. Once users are ready to update the code repository, they check the code back in. The version control software assigns a different version number to each check-in and allows users to rollback code to previous versions when necessary. In addition, the tool provides users with the ability to compare different versions of the code to each other in order to highlight changes and roll back to prior versions of application code if necessary. The ability to modify source code within the version control software is restricted to authorized development personnel. Version control administrative access privileges are restricted to members of the build and release team.

Software development projects are defined in one of two ways:

- **Feature Release** – Feature release projects contain new functionality and fixes to existing functionality. Product Management and Development Management jointly provide an update on the product vision for each feature release. The Product Owner determines the content of a patch release for their area of the product. They consult with technical support and the Scrum team (development team) to gather input into those decisions.

- Patch Release – A patch release generally follows the Scrum framework but may not apply to each step of a feature release. A hotfix includes fixes for problems in a supported release and is offered to those impacted by the problems that the hotfix resolves. Hotfix testing varies based on the risk of the change that is being introduced. Patch release and hotfix projects are released as needed.

Once a software development project has been initiated, the project is divided among development teams for sprint planning. The Scrum team and Product Owner collectively define a sprint goal and elaborate the stories or fixes (small change projects) which will comprise the sprint goal. Support and development personnel populate key fields on the ticket, including the change request description, priority level, test results, and approvals. Story and fix tickets are assigned to a development team member for proper response and handling.

Software development releases undergo quality assurance (QA) testing prior to their release. QA testing is performed for each story or fix ticket within a release. Test cases and results are documented within each ticket and QA support personnel update the test results within the story / fix ticket to denote that QA testing has been performed. In the event that the story or fix fails QA testing, it is sent back to development personnel for additional work. Once QA testing has commenced, the program manager reviews and approves QA test cases and results prior to release. The Program Manager is responsible for reviewing and approving feature releases and program managers are responsible for reviewing patches and hotfixes.

Approved release builds are placed on a secure server and are accessed via automation to upgrade or create new Now Platform instances. A build record in the Now Support Portal is leveraged to ensure only approved releases are used in the production environment. Developers do not have write access to the Now Platform production instance. Software change releases are made available to customers by the release management team via the Now Support Portal. The release management team does not maintain development responsibilities. Customers are given the option within the Now Support Portal to apply new software releases to their current software platforms. Once a customer opts to apply a new software release to their current platform, an automated script opens a Standard infrastructure change ticket for tracking and/or error resolution purposes and applies the software change to the customer environment. Release notes, user guides, and system descriptions are posted publicly via the ServiceNow documentation site.

The ability to release software upgrades to customers is restricted to user accounts accessible by authorized personnel. In the event that a customer is running an unsupported version of software or requires an emergency upgrade, the ability to provision software upgrades to customer systems is restricted to user accounts accessible by authorized personnel. Typically, emergency upgrade provisioning occurs only as a result of the customer self-upgrade tool not functioning correctly.

INFORMATION AND COMMUNICATION SYSTEMS

Relevant Information

ServiceNow offers its service under a cloud-based solutions business model. Customers can rapidly deploy ServiceNow's service in a modular fashion, allowing them to solve immediate business needs and access, configure, and build new applications as their requirements evolve. ServiceNow's service, which is accessed through a web-based interface, can be easily configured to adapt to customer workflows and processes. Upgrades to ServiceNow's service are designed to be efficient and compatible with configuration changes and applied with minimal disruption to ongoing operations.

The system can be utilized by the customer to generate various exports and customizable classification specific reports that include the following:

- IT performance reporting analytics
- Business services mapping
- Root cause and risk analysis

- Process management workflows
- Service level and spot trending
- Service and inventory cataloging
- Point-and-click graphical dashboards

Communication

Communication to internal stakeholders takes such forms as controlled documentation, to include formal policies, procedures, standards, and memoranda. Communications also can be made electronically, verbally, and through the actions of management. When applicable, ServiceNow has implemented various methods of communication to help provide assurance that employees understand their individual roles and responsibilities, and that significant events are communicated. These methods include orientation for new employees, training for employees, an internal Knowledge Base to communicate controlled documentation, and the use of e-mail messages to communicate time-sensitive information. Controlled documents are approved by a sponsor (management) before publishing and distributing to relevant parties. Employees are encouraged to communicate with their lead / mentor, supervisor / manager, or senior / executive management.

If incidents are detected, personnel follow a documented incident management process, and when necessary, security related incidents follow the security incident response process. Incidents are documented within the ticketing system and tracked by management until resolved.

MONITORING

Monitoring is a process that assesses the quality of internal control performance over time. It involves assessing the design and operation of controls and taking necessary corrective actions. This process is accomplished through ongoing control activities, third-party evaluation, or a combination of the two. Monitoring activities also include using information from communications from external parties such as user entity complaints and regulatory comments that may indicate problems or highlight areas in need of improvement. Management has implemented a self-assessment and compliance program to ensure the controls are consistently applied as designed.

Ongoing Monitoring

Examples of ServiceNow's ongoing monitoring activities include the following:

- Quarterly board of directors' meetings are held to review organization-wide performance.
- The production environment is monitored 24 hours per day by the SRE personnel for changes to the environment.
- ServiceNow reviews its data center authorized access user lists on a quarterly basis, at a minimum.
- ServiceNow periodically performs on-site reviews of the security and controls at the data centers that ServiceNow uses.
- Procedures executed by the SRE personnel for monitoring alerts and escalations.
- Selected security events are automatically sent to a centralized audit logging tool for review.
- Security personnel manually review the security events log exceptions on each business day.

Separate Evaluations

Management has implemented a self-assessment program to evaluate the performance of specific control activities and processes over time, and confirm that the in-scope controls were consistently applied as designed, including whether manual controls were applied by individuals who have the proper competence and authority. As a result of management's risk analysis process, each control activity within scope has been assigned a risk level associated

with the assessed level of risk it is intended to mitigate. Controls that serve to mitigate multiple risks are assigned the highest level of assessed risk among the pertinent risks.

Management has determined that each risk assignment or category will require structured inquiry, observation, inspection, or sample testing, or a combination of the aforementioned, based on the assigned risk level and the nature of the control, whether automated or manual, and the frequency of application (e.g., constant, daily, weekly, quarterly, etc.). For manual controls, the self-assessment is performed by a secondary individual different from the individual that primarily applies the control; additionally, subordinates do not evaluate the application of manual controls performed by their supervisors or managers.

Additionally, ServiceNow maintains a continuous control monitoring (CCM) program to evaluate the performance of specific control activities and processes at certain intervals based on risk and frequency of the control activity. The CCM program allows ServiceNow management to oversee the current state of monitored controls on a frequent basis. Control language, test instructions, and results are captured for each control under the monitoring program. The security compliance team executes the test to provide an independent review. Test results are captured and reported to control owners and the management team.

Internal and External Auditing

ServiceNow supports many user entities in their efforts to meet the regulatory demands of their industry or governing agency. Customers frequently perform their own audits of ServiceNow. ServiceNow is audited by multiple external third-party entities for certification and regulatory reasons on an annual basis.

ServiceNow has assisted user entities in successfully meeting the requirements of many certifications and regulatory demands, including:

- Type 2 System and Organization Controls (SOC) 1 examinations
- Type 2 SOC 2 examinations
- Health Insurance Portability and Accountability Act (HIPAA)
- Payment Card Industry Data Security Standard (PCI DSS)
- Sarbanes-Oxley (SOX)
- ISO/IEC 27001
- Federal Risk & Authorization Management Program (FedRAMP)
- 21 CFR Part 11

Monitoring of Subservice Organizations

ServiceNow data center operations, compliance, and procurement personnel review the co-location data center provider SOC reports or other available assessments (e.g., ISO/IEC 27001) on an annual basis. Additionally, through periodic visits to the facility, data center operations and compliance personnel review the controls applicable to the services provided to ServiceNow. Routine meetings are held with vendor account management personnel to help ensure services are provided according to expectations.

Reporting Deficiencies

Deficiencies in management's internal control system surface from many sources, including the company's ongoing internal monitoring procedures and external / periodic reviews of the internal control system. Management has developed protocols to help ensure findings of internal control deficiencies are reported to the individual responsible for the function or activity involved, who is in the position to take corrective action, and additional relevant personnel or team members. This process enables that individual to provide needed support or oversight for taking corrective action, and to communicate with others in the organization whose activities may be affected. Management evaluates the specific facts and a circumstance related to deficiencies in internal control procedures and makes the decision for addressing deficiencies based on whether the incident was isolated or requires a change in the company's procedures or personnel.

The ServiceNow ticketing system is utilized to record, track, and monitor identified issues or events. Documented procedures are in place to guide personnel in submitting tickets. The ticketing system is monitored to ensure identified issues or events are resolved. Additionally, a corrective action program is in place. A root-cause analysis is conducted and identified issues are tracked, reviewed by management, and monitored for resolution.

COMPLEMENTARY CONTROLS AT USER ENTITIES

ServiceNow's APaaS system is designed with the assumption that certain controls will be implemented by user entities. Such controls are called complementary user entity controls. It is not feasible for all of the control objectives related to ServiceNow's APaaS system to be solely achieved by ServiceNow's control activities. Accordingly, user entities, in conjunction with the APaaS system, should establish their own internal controls or procedures to complement those of ServiceNow.

The following complementary user entity controls should be implemented by user entities to provide additional assurance that the specified control objectives described within this report are met:

Control Activities Expected to be Implemented at User Entities	Related Control Objective
User entities are responsible for developing policies and procedures to protect their systems from unauthorized or unintentional use, modification, addition, or deletion.	Data Backup Logical Access Application Change Control
User entities are responsible for implementing and maintaining backup procedures for their data according to their own internal requirements, if their internal requirements are not satisfied by the 14-day backup retention provided by ServiceNow.	Data Backup
User entities are responsible for implementing and managing the retention of the data within their Now Platform instances according to their internal policy.	
User entities are responsible for implementing controls that ensure ServiceNow is notified of changes made to technical or administrative contact information.	Logical Access Data Communications Application Change Control
User entities are responsible for implementing controls that ensure the confidentiality of any user accounts and passwords assigned for use with their Now Platform instances.	Logical Access
User entities are responsible for implementing controls that ensure end-user access and issuing and securing login accounts and passwords are controlled for their Now Platform instances.	
User entities are responsible for implementing controls that ensure the implementation and configuration of the ServiceNow Controlled Access Plugin to restrict the ability of ServiceNow staff from accessing the application layer of their Now Platform instances if desired.	
User entities are responsible for implementing controls that ensure the Now Platform instance security hardening configurations are understood, and ensuring the instance is hardened according to their internal risk tolerance.	
User entities are responsible for implementing controls that ensure the level of encryption desired for their Now Platform instances and configuring said encryption.	

Control Activities Expected to be Implemented at User Entities	Related Control Objective
User entities are responsible for implementing controls that ensure monitoring of the Now Platform instances and that ServiceNow is notified of any known or suspected issues.	Logical Access Data Communications
User entities are responsible for implementing controls that ensure monitoring and reviewing of the Now Platform instance transaction logs for appropriateness.	
User entities are responsible for notifying ServiceNow of requested modifications to application functionality or features.	Application Change Control
User entities are responsible for testing and installing Now Platform releases, patches, and hotfixes.	
User entities are responsible for the management, testing and authorization of user-installed changes within their Now Platform instances.	

SECTION 4

TESTING MATRICES

TESTS OF OPERATING EFFECTIVENESS AND RESULTS OF TESTS

Scope of Testing

This report on the controls relates to the APaaS system provided by ServiceNow. The scope of the testing included the applicable controls for the APaaS system considered to be relevant to the internal control over financial reporting of respective user entities. Schellman & Company, LLC (Schellman) conducted the examination testing over the period October 1, 2023, through September 30, 2024.

Tests of Operating Effectiveness

The tests applied to test the operating effectiveness of controls are listed alongside each of the respective control activities within the Testing Matrices. Such tests were considered necessary to evaluate whether the controls were sufficient to provide reasonable, but not absolute, assurance that the specified control objectives were achieved during the period. In selecting the tests of controls, Schellman considered various factors including, but not limited to, the following:

- the nature of the control and the frequency with which it operates;
- the control risk mitigated by the control;
- the effectiveness of entity-level controls, especially controls that monitor other controls;
- the degree to which the control relies on the effectiveness of other controls; and
- whether the control is manually performed or automated.

The types of tests performed with respect to the operational effectiveness of the control activities detailed in this section are briefly described below:

Test Approach	Description
Inquiry	Inquired of relevant personnel with the requisite knowledge and experience regarding the performance and application of the related control activity. This included in-person interviews, telephone calls, e-mails, web-based conferences, or a combination of the preceding.
Observation	Observed the relevant processes or procedures during testing. This included, but was not limited to, witnessing the performance of controls or evidence of control performance with relevant personnel, systems, or locations relevant to the performance of control policies and procedures.
Inspection	Inspected the relevant evidentiary matter records. This included, but was not limited to, documents, system configurations and settings, or the existence of sampling attributes, such as signatures, approvals, or logged events. In some cases, inspection testing involved tracing events forward to consequent system documentation or processes (e.g., resolution, detailed documentation, alarms, etc.) or vouching backwards for prerequisite events (e.g., approvals, authorizations, etc.).

Sampling

Consistent with American Institute of Certified Public Accountants (AICPA) authoritative literature, Schellman utilizes professional judgment to consider the tolerable deviation rate, the expected deviation rate, the audit risk, the characteristics of the population, and other factors, in order to determine the number of items to be selected in a sample for a particular test. Schellman, in accordance with AICPA authoritative literature, selected samples in such a way that the samples were expected to be representative of the population. This included judgmental selection methods, where applicable, to ensure representative samples were obtained.

System-generated population listings were obtained whenever possible and evaluated for accuracy and completeness prior to selecting samples. In some instances, full populations were tested in cases including but not limited to, the uniqueness of the event or low overall population size.

Test Results

The results of each test applied are listed alongside each respective test applied within the Testing Matrices. Test results not deemed as control deviations are noted by the phrase “No exceptions noted.” in the test result column of the Testing Matrices. Any phrase other than the aforementioned constitutes a test result that is the result of a change in the application of the control activity, a deficiency in the operating effectiveness of the control activity, or a disclosure related to the non-occurrence of the condition(s) that would warrant the operation of the control. Testing deviations identified within the Testing Matrices are not necessarily weaknesses in the total system of controls at user entities, as this determination can only be made after consideration of controls in place at user entities, and other factors. Control considerations that should be implemented by user entities in order to complement the control activities and achieve the stated control objective are presented in the “Complementary Controls at User Entities” within Section 3.

DATA BACKUP

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Objective Specified by the Service Organization:			
Controls provide reasonable assurance that data relevant to user entities' internal control over financial reporting is backed up regularly and is available for restoration in the event of processing errors or unexpected processing interruptions.			
1.01	Customer environments are configured to replicate data on a real-time basis to a secondary database in a geographically separate location.	Inspected the replication configurations for a sample of production databases and an example replication status dashboard generated during the period to determine that customer environments were configured to replicate data on a real-time basis to a secondary database in a geographically separate location for each production database sampled.	No exceptions noted.
1.02	The automated backup system is configured to perform daily differential and weekly full data backups of production databases.	Inspected the automated backup system configurations for a sample of production databases and example backup logs generated during the period to determine that the automated backup system was configured to perform daily differential data backups and full data backups on a weekly basis for each production database sampled.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
1.03	The automated backup system is configured to retain at least six daily differential backups of production databases since the last full backup and at least two weekly full backups of production databases.	Inspected the automated backup system retention configurations and the backup files available during the period for a sample of production databases to determine that the automated backup system was configured to retain at least six daily differential backups since the last full backup and at least two weekly full backups for each production database sampled.	No exceptions noted.
1.04	Formal data failover and backup restoration tests are performed at least once per year.	Inspected the most recent backup failover and restoration test documentation to determine that formal data failover and backup restoration tests were performed during the period.	No exceptions noted.

SYSTEMS MONITORING

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Objective Specified by the Service Organization:			
Controls provide reasonable assurance that production problems, systems processing, and availability issues are monitored, identified, recorded, analyzed, and resolved completely and in a timely manner.			
2.01	An enterprise monitoring application is in place and configured to monitor production servers and network devices on a real-time basis for performance and availability statistics that include, but are not limited to, the following: • CPU usage • Disk space • Memory usage	Inspected the enterprise monitoring application configurations and example monitoring dashboards during the period to determine that an enterprise monitoring application was in place and configured to monitor production servers and network devices on a real-time basis for performance and availability statistics that included the following: • CPU usage • Disk space • Memory usage	No exceptions noted.
2.02	The enterprise monitoring application is configured to generate real-time alerts via monitoring dashboards and to generate automated tickets when predefined thresholds are exceeded. The SRE team resolves tickets on an as needed basis.	Inspected the alerting configurations, the monitoring dashboards during the period, and example alert tickets generated during the period to determine that the enterprise monitoring application was configured to generate real-time alerts via monitoring dashboards and to generate automated tickets when predefined thresholds were exceeded and that the SRE team resolved tickets during the period.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
2.03	Cases are logged in the Now Support Portal. Tickets for cases identified are tracked and managed until resolution in accordance with defined policies and procedures.	Inquired of the senior manager of security compliance regarding the case ticket remediation procedures to determine that cases were logged in the Now Support Portal and that tickets for cases identified were tracked and managed until resolution in accordance with defined policies and procedures.	No exceptions noted.
		Inspected the case ticket for a sample of priority one customer cases closed during the period to determine that each customer case sampled was logged in the Now Support Portal and that tickets for cases identified were tracked and managed until resolution.	No exceptions noted.
2.04	Problems are logged in the Now Support Portal. Tickets for problems identified are tracked and managed until resolution in accordance with defined policies and procedures.	Inquired of the senior manager of security compliance regarding the problem tickets remediation process to determine that problems were logged in the Now Support Portal and that tickets for problems identified were tracked and managed until resolution in accordance with defined policies and procedures.	No exceptions noted.
		Inspected the problem ticket for a sample of problems closed during the period to determine that each problem sampled was logged in the Now Support Portal and that tickets for problems identified were tracked and managed until resolution.	No exceptions noted.
2.05	A root cause investigation of priority one cases is performed. The root cause and remediation plans are documented.	Inspected the case ticket for a sample of priority one customer cases closed during the period to determine that a root cause investigation of each priority one case sampled was performed and that the root cause and remediation plans were documented.	No exceptions noted.

INFORMATION SECURITY

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Objective Specified by the Service Organization: Controls provide reasonable assurance that logical access to programs, data, and computer resources relevant to user entities' internal control over financial reporting is restricted to authorized and appropriate users and such users are restricted to performing authorized and appropriate actions.			
3.01	The operating systems for both the application and database servers are configured to log privileged command line use, login attempts, and account management.	Inspected the security event logging configurations for a sample of production application and database servers and an example log generated during the period to determine that the operating systems for both the application and database servers were configured to log privileged command line use, login attempts, and account management for each production application and database server sampled.	No exceptions noted.
3.02	A SIEM tool is configured to aggregate logs, alerts, and other activity from production infrastructure and to notify security personnel via alerting dashboards in real-time when predefined thresholds are met.	Inspected the log forwarding configurations and activity log configurations for a sample of production systems and example logs and alerting dashboards generated during the period to determine that a SIEM tool was configured to aggregate logs, alerts, and other activity from production infrastructure for each sampled production system and to notify security personnel via alerting dashboards in real-time when predefined thresholds were met.	No exceptions noted.
3.03	User access reviews for high-risk roles are performed on a quarterly basis to identify instances where user access is not commensurate with job responsibilities. Any discrepancies are identified and resolved.	Inspected the user access review for a sample of quarters during the period to determine that user access reviews for high-risk roles were performed to identify instances where user access was not commensurate with job responsibilities and that discrepancies were identified and resolved for each quarter sampled.	No exceptions noted.
3.04	ServiceNow support activity within customer instances is automatically logged to the customer's application transaction logs.	Inspected ServiceNow product documentation related to transaction logging and example transaction logs generated during the period to determine that ServiceNow support activity within customer instances was automatically logged to the customer's application transaction logs.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
3.05	For users selecting column level encryption, encrypted fields are stored in the database as unreadable cipher text. Access to encrypted fields at the application-level is role-based.	Inspected column level encryption configurations for the most recent software release and the encrypted fields role-based access configurations to determine that for users selecting column level encryption, encrypted fields were stored in the database as unreadable cipher text and that access to encrypted fields at the application-level was role-based.	No exceptions noted.
3.06	Network users for the Now Platform are required to authenticate via VPN client with multi-factor authentication via a user account, PIN, and token code prior to gaining access to the production network to perform any administrative or non-administrative activities.	Inspected the VPN authentication configurations to determine that network users for the Now Platform were required to authenticate via VPN client with multi-factor authentication via a user account, PIN, and token code prior to gaining access to the production network to perform any administrative or non-administrative activities.	No exceptions noted.
3.07	Termination information is entered into the HRIS as a component of the employee termination process. Automated workflows are configured to revoke system access based on the criteria entered into the HRIS.	Inspected the termination ticket, the automated termination workflow configurations, and the LDAP user account listing for a sample of employees terminated during the period to determine that termination information was entered into the HRIS as a component of the employee termination process and that automated workflows were configured to revoke system access based on the criteria entered into the HRIS for each terminated employee sampled.	No exceptions noted.
3.08	Predefined security groups are utilized to assign role-based access privileges and segregate access to data based on job function.	Inspected the LDAP security group configurations to determine that predefined security groups were utilized to assign role-based access privileges and segregate access to data based on job function.	No exceptions noted.
3.09	The LDAP centralized management tool is configured to automatically enforce the following password requirements for operating systems on the application and database servers: • Minimum password length and complexity • Minimum password history • Password expiration intervals • Invalid password account lockout threshold	Inspected the information security standard and the LDAP authentication configuration for a sample of application and database servers to determine that the LDAP centralized management tool was configured to automatically enforce the following password requirements for operating systems on the sampled application and database servers: • Minimum password length and complexity • Minimum password history • Password expiration intervals • Invalid password account lockout threshold	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
3.10	Production system user access requests are documented in a ticket and administrator level access requests require management approval.	Inspected the access request ticket for a sample of user access requests implemented during the period to determine that each user access request sampled was documented in a ticket and administrator level access requests received management approval.	No exceptions noted.
3.11	The following AD password requirements for operating system, applications, and databases are configured: • Minimum password length and complexity • Minimum password history • Password expiration intervals • Invalid password account lockout threshold	Inspected the information security standard and the corporate network domain authentication configuration to determine that the following AD password requirements for operating system, applications, and databases were configured: • Minimum password length and complexity • Minimum password history • Password expiration intervals • Invalid password account lockout threshold	No exceptions noted.

DATA COMMUNICATIONS

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Objective Specified by the Service Organization: Controls provide reasonable assurance that network infrastructure is configured as authorized to protect data relevant to user entities' internal control over financial reporting from unauthorized changes, and to support user entities' internal control over financial reporting.			
4.01	Network users for the Now Platform are required to authenticate via VPN client with multi-factor authentication via a user account, PIN, and token code prior to gaining access to the production network to perform any administrative or non-administrative activities.	Inspected the VPN authentication configurations to determine that network users for the Now Platform were required to authenticate via VPN client with multi-factor authentication via a user account, PIN, and token code prior to gaining access to the production network to perform any administrative or non-administrative activities.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
4.02	A SIEM tool is configured to aggregate logs, alerts, and other activity from production infrastructure and to notify security personnel via alerting dashboards in real-time when predefined thresholds are met.	Inspected the log forwarding configurations and activity log configurations for a sample of production systems and example logs and alerting dashboards generated during the period to determine that a SIEM tool was configured to aggregate logs, alerts, and other activity from production infrastructure for each sampled production system and to notify security personnel via alerting dashboards in real-time when predefined thresholds were met.	No exceptions noted.
4.03	An IDS is configured to analyze network events and to notify security personnel via alerting dashboards in real-time within the SIEM tool when suspected or actual network security breaches are detected.	Inquired of the senior manager security compliance regarding the IDS to determine that an IDS was configured to analyze and report network events and to send alert notifications to security operations personnel when suspected or actual network security breaches were detected.	No exceptions noted.
		Inspected the IDS configurations and example dashboards generated during the period to determine that an IDS was configured to analyze and report network events and to send alert notifications to security operations personnel when suspected or actual network security breaches were detected.	No exceptions noted.
4.04	A FIM tool is configured to monitor for changes to the production environment and to notify security personnel via alerting dashboards in real-time within the SIEM tool when changes are detected.	Inquired of the senior manager security compliance regarding the FIM tool to determine that a FIM tool was configured to monitor for changes to the production environment and to notify security personnel via alerting dashboards in real-time within the SIEM tool when changes were detected.	No exceptions noted.
		Inspected the FIM configurations and example dashboards generated during the period to determine that a FIM tool was configured to monitor for changes to the production environment and to notify security personnel via alerting dashboards in real-time within the SIEM tool when changes were detected.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
4.05	Security personnel are staffed on a 24 hour a day on-call basis to monitor SIEM dashboards and respond to security issues. Security personnel complete a security operations checklist on a business daily basis to help ensure that potential or actual security events are identified, documented, and remediated.	Inspected the on-call schedule and the security operations checklist for a sample of dates during the period and example monitoring dashboards generated during the period to determine that security personnel were staffed on a 24 hour a day on-call basis to monitor SIEM dashboards and respond to security issues and that security personnel completed a security operations checklist to ensure that potential or actual security events were identified, documented, and remediated for each date sampled.	No exceptions noted.
4.06	The firewall system is configured to deny any type of network connection that is not explicitly authorized by a firewall rule.	Inspected the firewall ruleset configuration for a sample of production firewalls to determine that the firewall system was configured to deny any type of network connection that was not explicitly authorized by a firewall rule for each production firewall sampled.	No exceptions noted.
4.07	Application and database servers are centrally managed using a server configuration tool.	Inspected the server management tool configurations for a sample of production application and database servers to determine that application and database servers were centrally managed using a server configuration tool for each production application and database server sampled.	No exceptions noted.

APPLICATION CHANGE CONTROL

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Objective Specified by the Service Organization:			
Controls provide reasonable assurance that changes to programs and related data management systems are authorized, tested, documented, approved, and implemented to support user entities'entities' internal control over financial reporting.			
5.01	Infrastructure changes are tested prior to implementation.	Inspected the change request ticket for a sample of infrastructure changes implemented during the period to determine that each infrastructure change sampled was tested prior to implementation.	No exceptions noted.
5.02	Infrastructure changes are approved prior to implementation.	Inspected the change request ticket for a sample of infrastructure changes implemented during the period to determine that each infrastructure change sampled was approved prior to implementation.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
5.03	Infrastructure changes are developed and approved by different individuals to maintain segregation of duties.	Inspected change request ticket for a sample of infrastructure changes implemented during the period to determine that each infrastructure change sampled was developed and approved by different individuals to maintain segregation of duties.	No exceptions noted.
		Observed the automated ticket workflow with the assistance of the senior security compliance manager to determine that infrastructure changes were developed and approved by different individuals to maintain segregation of duties.	No exceptions noted.
5.04	ServiceNow Platform family releases, patches, and hot fixes are tested prior to being made available to customers.	Inspected the change request ticket for a sample of application changes implemented during the period to determine that the ServiceNow Platform family releases, patches, and hot fixes were tested prior to being made available to customers for each application change sampled.	No exceptions noted.
5.05	ServiceNow Platform family releases, patches, and hot fixes are approved prior to being made available to customers.	Inspected the change request ticket for a sample of application changes implemented during the period to determine that ServiceNow Platform family releases, patches, and hot fixes were approved prior to being made available to customers for each application change sampled.	No exceptions noted.
5.06	Administrative access to the version control software is restricted to user accounts accessible by members of the build and release team.	Inspected the listing of user accounts with administrative access privileges to the version control software with the assistance of the senior security compliance manager to determine that administrative access to the version control software was restricted to user accounts accessible by members of the build and release team.	No exceptions noted.
5.07	Access to make software releases available to customers is restricted to user accounts accessible by the release management and quality teams who do not maintain development responsibilities.	Inquired of the senior security compliance manager regarding the users with access to make software releases available to customers to determine that access to make software releases available to customers was restricted to user accounts accessible by the release management and quality teams who did not maintain development responsibilities.	No exceptions noted.

#	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the listing of user accounts with the ability to release software upgrades to customers and the development entitlement configurations to determine that access to make software releases available to customers was restricted to user accounts accessible by the release management and quality teams who did not maintain development responsibilities.	No exceptions noted.